Actividad 15 — Propuesta de arquitectura de datos protegidos

1. Diseño conceptual de la arquitectura

La propuesta consiste en separar la información de los clientes en diferentes áreas según su finalidad. De esta manera, cada departamento tendrá acceso únicamente a los datos que necesita para realizar sus actividades, reduciendo el riesgo de exposición de información personal.

2. Descripción de las áreas

Área de operación: almacena y procesa los datos necesarios para atender a los clientes, como nombre, correo electrónico y teléfono cuando sean necesarios para el servicio. Los datos financieros o identificadores oficiales solo se conservarán cuando exista una finalidad justificada.

Área de analítica: recibe datos agregados o anonimizados para generar estadísticas mensuales. No necesita consultar directamente los nombres, correos electrónicos, teléfonos o RFC de los clientes.

Área de auditoría: conserva registros de quién accedió a la información, qué operaciones realizó y cuándo ocurrieron. Estos registros tendrán acceso restringido y no incluirán datos personales innecesarios.

3. Controles de privacidad y seguridad

Control	Propuesta técnica
Acceso	Crear roles y permisos independientes para operación, analítica, auditoría y desarrollo. Aplicar el principio de mínimo privilegio.
Minimización	Recopilar únicamente los datos necesarios para cada finalidad. Evitar que las áreas reciban campos que no utilizan.
Protección de información sensible	Cifrar los datos durante su almacenamiento y transmisión. Restringir el acceso a identificadores como el RFC y proteger las credenciales.
Retención	Definir plazos de conservación según la finalidad y las obligaciones legales aplicables. Revisar periódicamente los datos almacenados.

Trazabilidad	Registrar accesos, modificaciones, exportaciones y eliminaciones. Revisar los registros para detectar actividades sospechosas.
Eliminación	Eliminar los datos cuando termine su periodo de conservación y gestionar también sus copias de respaldo conforme a los procedimientos establecidos.
Atención de solicitudes	Establecer un procedimiento para atender solicitudes de acceso, rectificación, cancelación y oposición, según corresponda, verificando la identidad del solicitante.

4. Medidas adicionales

-Desarrollo y pruebas: utilizar datos sintéticos en lugar de copias completas con información real.
-Marketing: separar los datos utilizados para campañas y verificar que su uso tenga una base legal adecuada y respete las preferencias de los clientes.
-Responsables: asignar a cada área un responsable del uso, acceso y conservación de sus datos.
-Revisión periódica: comprobar que los permisos, las finalidades y los plazos de conservación continúen siendo adecuados.